

# Second-Round Beginner-Fix Legal & Compliance Notice (v3.38)

**Document nature:** Compliance reminder for ConfirmCard TTL extension, AI cost entry, backup/restore, undo, customer disambiguation. **Does not constitute legal advice.** Cumulatively applies to all §6 disclaimers in v3.25.10 → v3.37.

**Chinese version:** [POLISH\\_LEGAL\\_NOTICE\\_ZH.md](#)

## ⚠ Important: v3.38 fixes 8 issues found after v3.37 audit

v3.38 covers:

- ConfirmCard TTL changed from 5 min to 30 min (N1)
- Undo last admin change (N2) — rollback company info / password changes within 90 seconds
- Local database backup (N4) — full customer data copy to `./backups/`
- AI cost query (N3) — today / this month LLM API usage
- Customer disambiguation (N7) — multiple same-name candidates
- Business error sinicization (N6) — friendly ValueError / KeyError
- Chat cancel button + mobile responsive (N5, N8)

These functions, if misused, may cause:

- 🔴 During the 30-min TTL, **someone else with the same session may confirm** (security)
- 🔴 Backup file contains full customer data → leak = PDPA / Trade Secrets Act violation
- 🔴 Undo expires after 90 sec — customers **should not rely on undo** to replace careful operations
- 🔴 AI cost LLM tool data is **internal log only**; does **not** replace cloud vendor billing

## 1. ConfirmCard TTL from 5 min to 30 min (N1)

### 1.1 Motivation

- v3.37 customer feedback: "owner takes a phone call, comes back after 5 min, card expired"
- Changed to 30 min for realistic use

### 1.2 Side Effect / Risk

- If someone walks by during the same session, they could click "Confirm" to execute hard-write

- Customer should instruct employees: **lock screen when leaving seat** (Win + L / macOS Cmd+Ctrl+Q)
- Company should establish "auto-logout after 30 min idle" (planned for v3.x)

## 1.3 Legal Reminder

- For unlocked-screen mis-confirmations, **audit log records the logged-in account as the operator**
- Employees should acknowledge in their labor contract: **no password sharing, no session lending**
- For employee negligence (unlocked screen) causing mis-operation, erpilot is **not liable**; customer may pursue per company policy

# 2. Undo Last Admin Change (N2)

## 2.1 Coverage

- Company info changes ( `set_company_info_with_confirm` )
- Password changes ( `change_my_password_with_confirm` )
- **Does not cover:** customer / part / SO / PO / shipment etc. (v3.x roadmap)

## 2.2 Limits

- **90 seconds** undo window; cannot rollback after (in-memory stack)
- Only undo **latest** entry; no multi-step redo
- **No persistence:** backend restart clears the undo stack
- Not a replacement for formal **version history** / **audit rollback**

## 2.3 Risk Note

- Undoing password change = restore to **old password hash** — if customer forgot old password, undo leaves them **unable to log in**
- Undoing company info = restore to **previous** value — does not restore **earlier** versions

# 3. Local Database Backup (N4)

## 3.1 Scope

- SQLite only; PostgreSQL customers must use `pg_dump` via IT
- Stored at `./backups/erp-{timestamp}-{note}.db`
- Path configurable via `ERPILOT_BACKUP_DIR` env var

## 3.2 Backup Contents

The backup is a **full SQLite DB copy**, including:

- All customer, supplier, part, order **raw data**
- Employee / user **password hashes**
- AI conversation logs / audit logs

## 3.3 Customer Responsibility

- **Encrypt at rest** (recommended: 7-Zip + AES-256 + strong password)
- **Offsite storage** (local + cloud + different building)
- **Test restore regularly** (recommended: quarterly "new computer" simulation)
- **Retain ≥ 5 years** (Business Accounting Act §38)
- **Do not leak**: no public cloud upload, no email attachment

## 3.4 erpilot Responsibility Boundary

- erpilot provides the **interface** to trigger backup
- erpilot does **not** auto-schedule backups (v3.x roadmap)
- erpilot does **not** auto-offsite backup
- erpilot does **not** verify backup integrity — customer must `sqlite3 file.db .schema` to confirm

# 4. AI Cost Entry (N3)

## 4.1 Data Source

- `query_ai_cost_today` / `query_ai_cost_this_month` read `DecisionLog.cost_usd`
- Written by erpilot's `governance.py` tracker after each LLM call

## 4.2 Limits

- erpilot internal log **may differ from cloud vendor billing** (model upgrades, bugs, missed entries)
- Customer's **official financial reconciliation** should use **cloud API vendor invoice / console**
- TWD conversion uses approximate rate (1 USD ≈ 31.5 TWD), **reference only**

## 4.3 Alert Thresholds

- Daily cost > \$0.5 USD → show "⚠️ Higher usage"
- Monthly cost > \$5 USD → show "⚠️ Exceeded monthly budget recommendation"
- Customer can adjust in their own `governance.py`

## 5. Customer Disambiguation (N7)

### 5.1 Purpose

- "ABC" may match "ABC Inc.", "ABC Industries", "ABC Trading" — three records
- `resolve_customer_candidates` lists up to 10 candidates + code + grade
- User confirms by code / full name / grade

### 5.2 Risk

- LLM should **not** auto-select — should **ask user**
  - Customer must train sales: **confirm candidate list** before ordering
- 

## 6. Business Error Sinicization (N6)

### 6.1 Scope

New global handlers for `ValueError` / `KeyError` :

- If already Chinese → keep as is
- If English → add "輸入值有誤：" (Input invalid:) prefix
- Add hint "Please check input..."

### 6.2 Limits

- Does **not** replace deep Python traceback log (IT still checks log)
  - Not covered: `TypeError`, `AttributeError` etc. — still falls through `Exception` "system busy"
  - Customer's **specific business errors** should still be raised as `BusinessRuleError` with clear Chinese
- 

## 7. Chat Cancel Button + Mobile Responsive (N5, N8)

### 7.1 Cancel Button

- User can press "■ Cancel" if AI takes too long
- Frontend `AbortController` aborts fetch; **backend LLM may continue burning tokens** (backend abort = v3.x roadmap)

### 7.2 Mobile Responsive

- Chat usable on mobile browser (< 640px): smaller text, narrower button spacing, 92% bubble width

- **Not** equivalent to a native app — does **not** support offline, push notifications, camera barcode scan
- v3.0 cut Mobile App from roadmap; this is just "desktop Chat usable on phone" as transition

## 8. Disclaimer (Cumulative v3.25.10 → v3.38)

To the maximum extent permitted by applicable law:

1. **TTL Extension** Changing TTL from 5 to 30 min is a **functional adjustment**; customer must reinforce seat-lock / auto-logout policy; erpilot is **not liable** for mis-confirmations caused by extended TTL.
2. **Undo** `undo_last_admin_change` is a **convenience feature**; does **not** replace formal version history / audit rollback; expires after 90 sec; erpilot is **not liable** if customer relies on undo and neglects careful operation.
3. **Backup** Backup is a **customer-initiated action**; erpilot provides the tool but is **not** responsible for the storage, encryption, leakage, or corruption of backup files; customer must comply with PDPA, Trade Secrets Act, Business Accounting Act.
4. **AI Cost** `query_ai_cost_*` is **internal estimation**; does **not** replace cloud vendor billing; customer should use **vendor official invoice** for month-end reconciliation.
5. **Disambiguation** The candidate list is **search results only**; erpilot does **not** guarantee that customers in the database are "legal, existing, valid" business entities; customer must verify counterparty identity.
6. **Cancel Button / Mobile Responsive** Frontend abort does **not** guarantee backend LLM stops; mobile-usable does **not** equal supporting all business scenarios; customer must evaluate fit.

## 9. Pre-Adoption Checklist (v3.38 reinforced)

Before adopting erpilot v3.38, please confirm:

### 9.1 Employee Training (Important)

- ☐ Inform employees of **30-min TTL**: lock screen when leaving seat
- ☐ Explain **Undo 90 sec**: only for admin operations, don't rely on it
- ☐ **Backup frequency**: at least weekly + offsite
- ☐ **AI cost**: use cloud vendor invoice for monthly reconciliation

### 9.2 Internal Control Policy

- ☐ Established "auto screen-lock when away" IT policy (Win + L / 30 min idle)
- ☐ Established "encrypted + offsite" backup SOP

- ☐ Established "data leak reporting" internal control flow
- ☐ Provided 30-min v3.38 new-feature training to employees

### 9.3 Technical Configuration

- ☐ `ERPILOT_BACKUP_DIR` env var set to host storage (not docker volume cleared by `docker compose down` )
- ☐ Tested complete "backup → simulated restore" flow
- ☐ Confirmed SQLite → PostgreSQL upgrade path (production recommends PG)

### 9.4 Cumulative with Existing Checklists

- ☐ Completed all v3.25.10 → v3.37 checklists

---

**Version:** v3.38 (2026-05-21) **Author:** erpilot Legal Team (internal) **Corresponds to code:**

- `backend/app/agents/confirm_card.py` (TTL → 30 min)
- `backend/app/agents/domains/polish_tools.py` (6 LLM tools)
- `backend/app/agents/domains/setup_wizard_tools.py` (push\_undo integration)
- `backend/app/core/exceptions.py` (ValueError + KeyError handler)
- `frontend-desktop/src/pages/Chat.tsx` (cancel button + mobile responsive)
- `frontend-desktop/src/lib/api.ts` (AbortSignal support)